パトロールシフト管理サイト　確認事項

セキュリティ・個人情報に関する確認（2026年10月25日時点）／作成：蔵本

No.	内容	重要度	対応
1	スプレッドシート4つが、URL を知っていれば誰でも読める	すぐ LINE の鍵・電話番号が見える	共有設定の変更＋LINE の鍵の再発行（コード変更なし）
2	サイトの裏側（API）を、URL を知っていれば誰でも呼べる	早めに 通知の乱用・データの書き換え	合言葉方式の導入（コード変更あり）
3	最初の画面のデータに、電話番号・ニーズ調査の ID/PW が含まれる	早めに 個人情報・ログイン情報	必要な画面だけで読むよう分ける（コード変更あり）

1．スプレッドシートが誰でも読める状態

現状

- 次の4つのスプレッドシートは、一般的なアクセスが「リンクを知っている全員」になっています。ログインしていない状態でも中身を読めることを確認しました。
  - 基本（メンバー・投票・設定）／AST業務報告／業務報告関連／パトロールマスタデータ
- スプレッドシートの ID は、公開しているサイト（GitHub）の「各種シート」のリンクに書かれています。そのため、実質だれでもたどり着けます。

何が見えてしまうか

基本 ＞ 設定シート	**LINE のチャネルアクセストークン**（公式アカウントからメッセージを送れる鍵）。悪用されると、公式アカウントとして勝手に送信されたり、月200通を使い切られたりします。
業務報告関連 ＞ 報告者情報	氏名・フリガナ・**電話番号**・業務内容
そのほか	メンバー名、シフト、投票、完了報告、業務報告の内容、LINE 登録（名前と LINE のユーザーID）

対応手順（コードの変更は不要）

1. 4つのスプレッドシートを順に開き、右上の「共有」を押す。
2. 「一般的なアクセス」を「**制限付き**」に変える。
3. 「ユーザーやグループを追加」に、**チーム用アカウント（astpatrol.student@gmail.com）**を「編集者」で追加する（追加済みなら不要）。

4. スプレッドシートを直接開く必要があるメンバーだけを、個別に追加する（閲覧者か編集者）。
5. LINE Developers →「ASTパトロール」→「Messaging API設定」→ 一番下の「チャネルアクセストークン（長期）」で**再発行**する。新しいトークンを設定シートの `LINE_CHANNEL_ACCESS_TOKEN` に貼り直す。
6. サイトの ⚙ →「LINE通知」→「自分にテスト送信」で、届くことを確認する。

止まらないもの：サイトはチーム用アカウントの権限で読み書きしているので、手順1〜4のあともそのまま動きます。
公開のままでよいもの：「パトロールシフト_表示用（自動作成）」のスプレッドシート。初めて開くときの表示を速くするためのもので、氏名・電話番号・ID/PW・LINE のユーザーID は入れていません。
影響：サイトの「各種シート」のリンクは、共有に追加された人だけが開けるようになります。

確認

☐ 4つとも「制限付き」になっている
☐ チーム用アカウントが4つとも「編集者」に入っている
☐ LINE のトークンを再発行し、設定シートに貼り直した
☐ テスト送信が届いた／サイトが普通に開ける

2．サイトの裏側（API）を誰でも呼べる

現状

- 「ログインなし・名前を選ぶだけ」の方針のため、サイトが使っている Apps Script の URL を知っていれば、誰でも操作を呼び出せます。
- Apps Script の URL は、公開しているサイトの中に書かれています。

起こりうること

通知の乱用	「テスト送信」を繰り返し呼ばれると、LINE の月200通を使い切られ、本来のお知らせが届かなくなる
データの書き換え	メンバーの追加・休止、シフトの保存・確定、業務報告の削除、完了報告の取り消しなど
データの読み出し	最初の画面のデータ（3 の内容を含む）

対応案（コードの変更が必要）

1. **合言葉方式**（おすすめ）：書き込みと送信の操作だけ、チームの合言葉を最初に1回入れてもらい、端末に記憶する。見るだけの操作はこれまでどおり。合言葉は設定シートで変えられるようにする。
2. **送信の回数制限**：テスト送信は1人1日数回まで、など。1 と組み合わせるとより安全。
3. **Google ログイン方式**：最も安全。ただし「ログインなし」の方針が変わるうえ、慶應のアカウントでログインしたブラウザで開けない問題が再発するおそれがあるため、おすすめしない。

決めてほしいこと

☐ 合言葉方式にするか（する場合、合言葉は誰が決めて、どう共有するか）

☐ 合言葉が必要な操作の範囲（例：完了報告や投票も含めるか、シフト確定・削除・送信だけにするか）

3．最初の画面のデータに個人情報・ID/PW が含まれる

現状

- サイトを開いたときに取ってくるデータに、メンバーの**氏名・フリガナ・電話番号**（業務報告書用）と、**ニーズ調査の ID/PW** が含まれています。
- 画面には出ていなくても、2 のとおり URL を知っていれば誰でも取得できます。
- 端末（ブラウザ）への保存と表示用シートには、これらを**入れないよう対策済み**です。

対応案（コードの変更が必要）

1. 電話番号などは、「業務報告」タブで自分の報告者情報を開いたときだけ取りに行く。
2. ニーズ調査の ID/PW は、⚙ の「ニーズ調査」を開いたときだけ取りに行く（2 の合言葉方式と組み合わせると、合言葉を知っている人だけが見られる）。

決めてほしいこと

☐ 1・2 の分け方で進めてよいか

☐ ニーズ調査の ID/PW を、合言葉の対象にするか

補足：1 はコードを変えずにすぐできます。2・3 は、決まった内容に合わせてサイトを更新します（作業後は Code.gs・index.html の差し替えが必要です）。